SOC Incident Report — GHA6 Trojan Compromise

Malware infection and endpoint compromise via a fake pirated-game download

Author: Sawhard Poojari | Date: 22 October 2026 | Environment: Home SOC Lab (isolated)

---

1. Incident Overview

Incident Title: Trojan Compromise via Fake Game Download (GHA6)

Incident Type: Malware Infection / Endpoint Compromise

Date & Time: 22 October 2026, between 14:10 and 14:36 IST

Reported By: SOC Analyst (Lab Environment)

Summary: A Windows endpoint was compromised after a user downloaded and ran a trojan disguised as a pirated game installer. The attacker gained a remote shell, escalated privileges through a UAC bypass, created a backdoor administrator account, and established registry persistence. All stages were detected by Wazuh SIEM.

2. Affected Asset

System: Windows 11 Pro (Virtual Machine)

Hostname: DESKTOP-4VD18QN

IP Address: 192.168.64.4

Affected User: soc-admin

Log Sources: Sysmon (endpoint telemetry) and Windows Security Event Logs

SIEM Platform: Wazuh (Manager, Indexer, Dashboard)

Attacker Host: 192.168.64.7 (Kali Linux)

3. Detection Method

The incident was detected through Wazuh SIEM alerts generated from Sysmon and Windows Security telemetry forwarded by the Wazuh agent. The investigation began from a critical alert: Rule 60154 - Administrators Group Changed (level 12). Filtering the dashboard to high-severity alerts surfaced the full attack, which was then investigated by pivoting through related events.

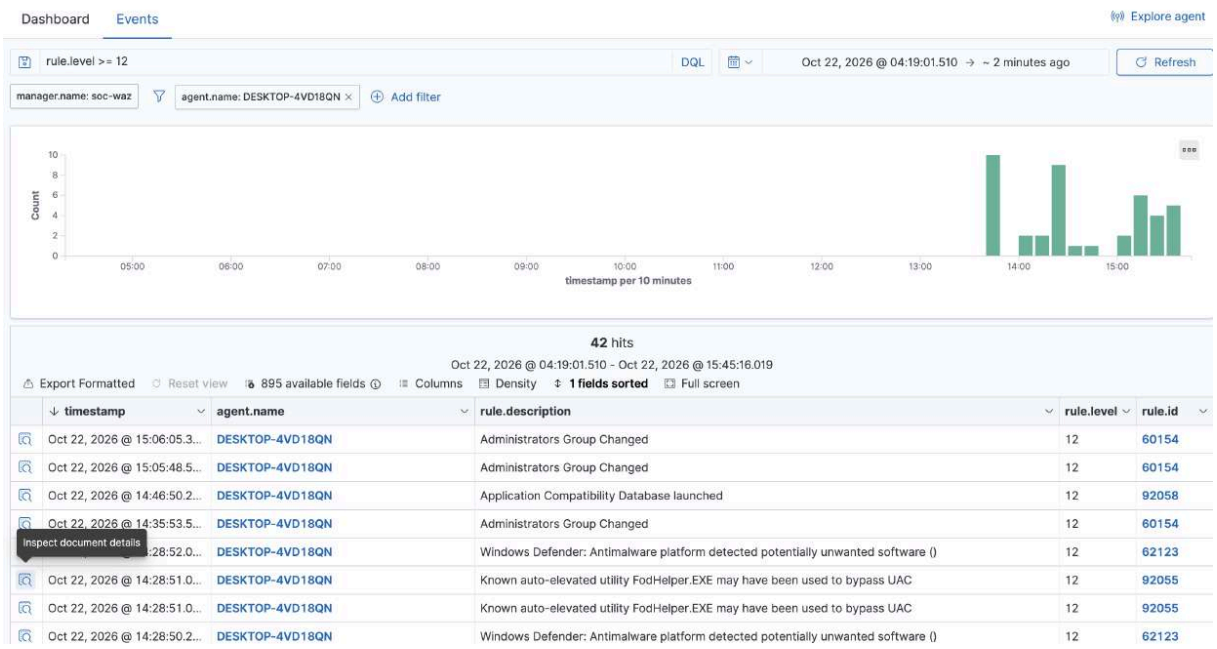


Figure: Critical alerts (rule.level >= 12) that triggered the investigation

4. Incident Description

A user on DESKTOP-4VD18QN browsed to a fake pirated-game website and downloaded an installer named GHA6-Setup.exe. The file was actually a trojan. When the user ran it, it opened a reverse shell to the attacker at 192.168.64.7 on port 4444.

The attacker then performed a UAC bypass using fodhelper.exe to gain administrator privileges, created a backdoor account named svc_helpdesk, added it to the local Administrators group, and set a registry Run key so the payload would relaunch on every logon. The attack moved from initial access to full administrative compromise and persistence within about 26 minutes.

5. Incident Timeline

All times are local (IST).

Time	Event	Detecting rule
14:10	Trojan GHA6-Setup.exe downloaded via Chrome and dropped to disk	92213 (L15)
14:17	Payload executed, reverse shell to 192.168.64.7:4444	100103 / 100104
14:28	UAC bypass attempt via fodhelper.exe; Defender detection	92055, 92305, 62123 (L12)
14:31	Re-infection with elevated (admin) shell	100103
14:35	Backdoor account svc_helpdesk created	60109 (L8)
14:35	svc_helpdesk added to Administrators group	60154 (L12)
14:36	Registry Run-key persistence (GHA6Updater) set	100108 (L8), 92041 (L10)

6. Investigation Details

The investigation started from the critical alert and worked backward to the root cause:

- The Administrators Group Changed alert (60154) showed an account with SID -1006 added to Administrators by soc-admin.
- Pivoting to account-creation events identified the account as svc_helpdesk, created seconds earlier.
- Searching further back revealed a UAC bypass (fodhelper.exe launched by cmd.exe, running at High integrity).
- Pivoting on the payload GHA6-Setup.exe showed it executing and connecting to 192.168.64.7:4444 (command-and-control).
- The file-creation event showed chrome.exe created the file, with a Zone.Identifier stream confirming it was downloaded from the internet.

t	data.win.system.version	0
t	decoder.name	windows_eventchannel
t	id	1792659953.4808785
t	input.type	log
t	location	EventChannel
t	manager.name	soc-waz
t	rule.description	Administrators Group Changed
#	rule.firedtimes	1
t	rule.gdpr	IV_35.7.d, IV_32.2
t	rule.gpg13	7.10
t	rule.groups	windows, windows_security, group_changed, win_group_changed
t	rule.hipaa	164.312.a.2.I, 164.312.a.2.II, 164.312.b
t	rule.id	60154
#	rule.level	12
◔	rule.mail	true
t	rule.mitre.id	T1484
t	rule.mitre.tactic	Defense Evasion, Privilege Escalation
t	rule.mitre.technique	Domain Policy Modification
t	rule.nist_800_53	AC.2, IA.4, AU.14, AC.7
t	rule.pci_dss	8.1.2, 10.2.5
t	rule.tsc	CC6.8, CC7.2, CC7.3
🗓	timestamp	Oct 22, 2026 @ 14:35:53.523

Figure: Privileged group change (rule 60154) - svc_helpdesk added to Administrators

Table JSON

t _index	wazuh-alerts-4.x-2026.10.22
t agent.id	001
t agent.ip	192.168.64.4
t agent.name	DESKTOP-4VD18QN
t data.win.eventdata.creationUtcTime	2026-10-22 08:44:16.704
t data.win.eventdata.image	C:\\Program Files\\Google\\Chrome\\Application\\chrome.exe
t data.win.eventdata.processGuid	{6df2c386-ccea-6ad9-ee02-000000006600}
t data.win.eventdata.processId	6512
t data.win.eventdata.ruleName	Downloads
t data.win.eventdata.targetFilename	C:\\Users\\soc-admin\\Downloads\\GHA6-Setup.exe:Zone.Identifier
t data.win.eventdata.user	DESKTOP-4VD18QN\\soc-admin
t data.win.eventdata.utcTime	2026-10-22 08:44:26.404
t data.win.system.channel	Microsoft-Windows-Sysmon/Operational
t data.win.system.computer	DESKTOP-4VD18QN
t data.win.system.eventID	11
t data.win.system.eventRecordID	68599
t data.win.system.keywords	0x8000000000000000
t data.win.system.level	4
t data.win.system.message	"File created:

Figure: Root cause - trojan downloaded via chrome.exe (Zone.Identifier present)

Key findings: the root cause was a user downloading a trojan from an untrusted website; the attacker achieved administrator privileges via UAC bypass; a backdoor admin account and registry persistence were established; the backdoor account showed "Last logon: Never", indicating it was created for future re-entry but not yet used. One false lead (a normal PowerShell __PSScriptPolicyTest file) was correctly ruled out during the investigation.

7. Indicators of Compromise (IOCs)

Type	Indicator
Malicious file	GHA6-Setup.exe
SHA256	9553F7DA5E10519E3D39C34A4CDE56CF88D6A10D5CA0940453C0372CF1E581E9
File path	C:\Users\soc-admin\Downloads\GHA6-Setup.exe

Attacker IP	192.168.64.7
C2 port	4444 (TCP)
Delivery site	http://192.168.64.7/ (fake GHA6 download page)
Backdoor account	svc_helpdesk
Persistence key	HKCU\...\CurrentVersion\Run\GHA6Updater
Technique marker	fodhelper.exe spawned by cmd.exe

8. MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Phishing / Drive-by Compromise	T1566 / T1189
Execution	User Execution: Malicious File	T1204.002
Command and Control	Ingress Tool Transfer	T1105
Command and Control	Application Layer Protocol	T1071
Privilege Escalation / Defense Evasion	Bypass User Account Control	T1548.002
Persistence	Create Account: Local Account	T1136.001
Privilege Escalation	Account / Policy Modification	T1484 / T1098
Persistence	Registry Run Key	T1547.001

9. Analysis

The activity is consistent with a trojan infection delivered through social engineering. The attacker followed a standard post-exploitation path: gain access, escalate privileges, create a backdoor, and establish persistence. The use of a disguised account name (svc_helpdesk) and a legitimate-looking Run key (GHA6Updater) shows an attempt to blend in with normal system activity. As this activity was generated intentionally in a controlled lab environment, it is classified as a simulated incident.

10. Severity Assessment

Severity Level: High

Reasoning: The attacker achieved remote code execution, escalated to administrator privileges, created a privileged backdoor account, and established persistence. This represents a full compromise of the endpoint. On a production host, this would require isolation and reimaging.

11. Response Taken

Containment and eradication steps performed:

1. Disabled and deleted the backdoor account svc_helpdesk.
2. Removed the registry Run key GHA6Updater.
3. Deleted the payload GHA6-Setup.exe from the Downloads folder.
4. Closed the attacker's shell and listener.
5. Removed the lab Windows Defender exclusions to restore full protection.

An automated containment response was also built in Wazuh to disable the backdoor account when the Administrators Group Changed alert fires. The containment script was validated and works when invoked directly; automatic dispatch to the ARM Windows agent did not complete reliably, so containment for this incident was performed manually. The active-response script was developed with assistance from Claude.

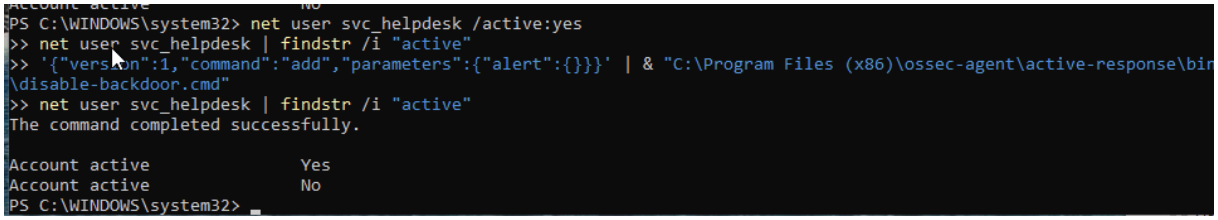


Figure: Containment script disabling the backdoor account (active Yes to No)

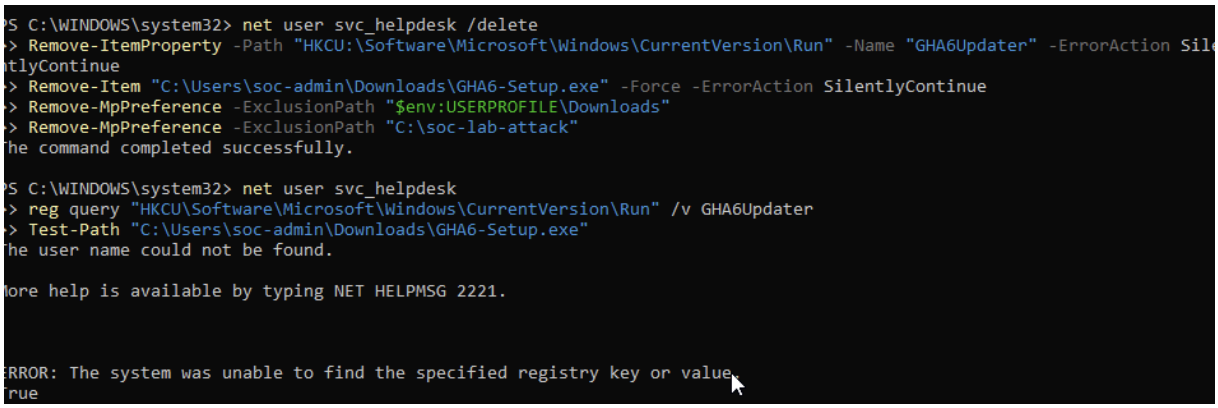


Figure: Eradication verified - backdoor, persistence, and payload removed

12. Recommendations

If this activity were observed in a production environment, the following actions are recommended:

- Remove local administrator rights from standard user accounts to limit privilege escalation.
- Enforce application allow-listing so unsigned downloaded installers cannot run.
- Keep Windows Defender real-time protection enforced and prevent users from disabling it.
- Block access to known pirated-software and warez sites through web filtering.
- Alert on privileged-group changes using the group SID, not the account name.
- Monitor for UAC-bypass techniques such as fodhelper.exe abuse.
- Add network or DNS monitoring (for example Zeek) to catch C2 channels Sysmon does not capture.

13. Incident Status and Analyst Notes

Current Status: Closed

Closure Reason: Simulated lab activity with no production impact. Host remediated.

Analyst Notes: This incident shows how a single user action, downloading a cracked game, can lead to a full endpoint compromise within minutes. It also demonstrates the value of endpoint telemetry and SIEM correlation: even where the attacker tried to blend in or where a technique failed, the activity remained visible in

the logs. The investigation was carried out by starting from one alert and pivoting through the SIEM back to the root cause, which is the core skill of a SOC analyst.